Frontend API Reference (Website/App + Dashboard)

This document is written for frontend developers to integrate with the current backend endpoints.

- Base URL (local): `http://127.0.0.1:8000`
- In examples, `{{baseurl}}` means the same base URL (e.g. `http://127.0.0.1:8000`).
- Swagger UI: `/`
- OpenAPI schema: `/api/schema/`
- All endpoints below include a trailing slash.

Website/App vs Dashboard (how to read this doc)

We separate endpoints by the **frontend consumer**:

- **Website/App**: public endpoints (`AllowAny`) + customer endpoints (role `customer`).
- **Dashboard**: any endpoint that requires role `staff`, `manager`, `superuser`, and **Articles write** endpoints for role `content_creator`.

Some endpoints are shared (e.g., `/api/auth/login/`, `/api/auth/me/`) because both website/app users and dashboard users must authenticate.

Quick index (by frontend consumer)

Website/App

- Auth (public): `POST /api/auth/register/`, `POST /api/auth/login/`, `POST /api/auth/refresh/`
- Auth (customer): `GET|PATCH|PUT /api/auth/me/`, `POST /api/auth/logout/`
- Public lists/details: `GET /api/countries/`, `GET /api/cities/`, `GET /api/sliders/`, `GET /api/ads/`, `GET /api/features/`, `GET /api/articles/`
- Unit Types (public): `GET /api/unit/types/`, `GET /api/unit/types/{id}/`
- Customer Inquiry: `POST /api/customer/inqury/`

Dashboard

- Auth (dashboard users): `POST /api/auth/login/`, `POST /api/auth/refresh/`, `GET|PATCH|PUT /api/auth/me/`, `POST /api/auth/logout/`
- Core management:
  - Countries/Cities/Sliders/Ads/Features: write for `staff|manager|superuser`, delete for `manager|superuser`
  - Articles: write/delete for `content_creator|manager|superuser`
- Unit Types management: write for `staff|manager|superuser`, delete for `manager|superuser`
- Customer Inquiries:
  - `GET /api/customer/inqury/` (list all)
  - `PATCH /api/customer/inqury/{id}/contacted/` (toggle follow-up status)

Authentication

JWT header

For protected endpoints, send:

- `Authorization: Bearer <access_token>`

Swagger tip

In Swagger (`/`), click **Authorize** and paste: `Bearer <access_token>`.

Tokens

- `access`: short-lived JWT access token
- `refresh`: long-lived refresh token

Token claims also include `user_id`, `email`, `role`, `full_name`.

Auth endpoints (`/api/auth/`)

Register

- **POST** `/api/auth/register/`
- **Auth**: No
- **Creates**: User with role `customer` by default
- **Content-Type**: `application/json` (or `multipart/form-data` if uploading `profile_image`)

Request body fields

Required:

- `email` (string, unique)
- `full_name` (string)
- `password` (string)
- `password_confirm` (string; must match `password`)

Optional:

- `phone` (string; digits with optional leading `+`; can be null)
- `profile_image` (file upload)

Example (JSON)

```
{
  "email": "user@example.com",
  "full_name": "John Doe",
  "phone": "201234567890",
  "password": "StrongPassword123!",
```

```
  "password_confirm": "StrongPassword123!"
}
```

Success response

- **201 Created**

```
{
  "message": "User registered successfully",
  "refresh": "<refresh_token>",
  "access": "<access_token>",
  "access_expires_at": "2025-12-29T15:00:00+00:00",
  "refresh_expires_at": "2026-01-28T15:00:00+00:00",
  "access_expires_in": 86400,
  "refresh_expires_in": 2592000,
  "user": {
    "id": 1,
    "email": "user@example.com",
    "full_name": "John Doe",
    "phone": "201234567890",
    "role": "customer",
    "profile_image": null,
    "is_active": true,
    "created_at": "2025-12-25T12:34:56Z",
    "updated_at": "2025-12-25T12:34:56Z"
  }
}
```

Common error responses

- **400 Bad Request** (validation)

```
{
  "email": ["A user with this email already exists."]
}
```

```
{
  "password": ["Password fields didn't match."]
}
```

```
{
  "password": ["This password is too short. It must contain at least 8
characters."]
}
```

Login

- **POST** `/api/auth/login/`
- **Auth**: No
- **Content-Type**: `application/json`

Request body fields

Required:

- `email` (string)
- `password` (string)

Example

```
{
  "email": "user@example.com",
  "password": "StrongPassword123!"
}
```

Success response

- **200 OK**

```
{
  "refresh": "<refresh_token>",
  "access": "<access_token>",
  "access_expires_at": "2025-12-29T15:00:00+00:00",
  "refresh_expires_at": "2026-01-28T15:00:00+00:00",
  "access_expires_in": 86400,
  "refresh_expires_in": 2592000,
  "user": {
    "id": 1,
    "email": "user@example.com",
    "full_name": "John Doe",
    "role": "customer",
    "phone": "+201234567890",
    "profile_image": "{{baseurl}}/media/users/profiles/profile.webp"
  }
}
```

Token expiry fields

- `access_expires_at`, `refresh_expires_at`: ISO timestamps
- `access_expires_in`, `refresh_expires_in`: seconds remaining (dynamic)

Common error responses

- **401 Unauthorized**

```
{
  "detail": "No active account found with the given credentials"
}
```

Refresh token

- **POST** `/api/auth/refresh/`
- **Auth**: No
- **Content-Type**: `application/json`

Request body fields

Required:

- `refresh` (string)

Example

```
{
  "refresh": "<refresh_token>"
}
```

Success response

- **200 OK**

With rotation enabled, the backend may return both a new access token and a new refresh token:

```
{
  "access": "<new_access_token>",
  "refresh": "<new_refresh_token>"
}
```

If rotation is disabled in the future, response may be:

```
{
  "access": "<new_access_token>"
}
```

Common error responses

- **401 Unauthorized** (expired/invalid refresh token)

```
{
  "detail": "Token is invalid or expired",
  "code": "token_not_valid"
}
```

Logout (blacklist refresh token)

- **POST** `/api/auth/logout/`
- **Auth**: Yes (access token required)
- **Content-Type**: `application/json`

Request body fields

Required:

- `refresh` (string)

Example

```
{
  "refresh": "<refresh_token>"
}
```

Success response

- **205 Reset Content**

```
{
  "message": "Successfully logged out"
}
```

Common error responses

- **400 Bad Request** (missing/invalid refresh)

```
{
  "error": "Refresh token is required"
}
```

- **401 Unauthorized** (missing/invalid access token)

Me (current user profile)

- **GET** `/api/auth/me/` (retrieve)
- **PATCH** `/api/auth/me/` (partial update)
- **PUT** `/api/auth/me/` (full update)
- **Auth**: Yes

Response fields

```
{
  "id": 1,
  "email": "user@example.com",
  "full_name": "John Doe",
  "phone": "+201234567890",
  "role": "customer",
  "profile_image": "{{baseurl}}/media/users/profiles/profile.webp",
  "is_active": true,
  "created_at": "2025-12-25T12:34:56Z",
  "updated_at": "2025-12-25T12:35:10Z"
}
```

Updatable fields

- `email` (string)
- `full_name` (string)
- `phone` (string or null)
- `profile_image` (file upload; use `multipart/form-data`)
- `is_active` (boolean)

Not updatable:

- `role` (read-only)
- `created_at`, `updated_at` (read-only)

PATCH example (JSON)

```
{
  "full_name": "John Doe Updated",
  "phone": "+201000000000"
}
```

Common error responses

- **401 Unauthorized** (missing/invalid token)

Authorization & roles (summary)

Roles (string values):

- `customer`
- `developer`
- `content_creator`
- `staff`
- `manager`
- `superuser`

Core permission rules implemented in `apps/core/permissions.py`.

Core API endpoints (`/api/`)

Common responses

- List: **200 OK** → JSON array of objects
- Retrieve: **200 OK** → JSON object
- Create: **201 Created** → created JSON object
- Update (PUT/PATCH): **200 OK** → updated JSON object
- Delete: **204 No Content**

Common errors

- **400 Bad Request**: serializer validation errors
- **401 Unauthorized**: missing/invalid JWT on protected routes
- **403 Forbidden**: authenticated but insufficient role
- **404 Not Found**: invalid `{id}`

Search (text)

Many list endpoints support a `search` query param:

- Example: `GET /api/countries/?search=cai`
- Searches in `name_en` / `name_ar` or `title_en` / `title_ar` depending on the resource.

Supported (current):

- Countries: `name_en`, `name_ar`
- Cities: `name_en`, `name_ar`
- Features: `name_en`, `name_ar`
- Unit Types: `name_en`, `name_ar`
- Articles: `title_en`, `title_ar`
- Developers: `name_en`, `name_ar`

Uploading `image` fields

Several core resources include an `image` field.

- When sending an image file, use `multipart/form-data`.
- When not uploading a file (e.g., only changing text fields), `application/json` is fine.

Allowed image formats (server validation)

- WebP only: all image uploads by default (Countries, Cities, Ads, Articles, etc.)
- Exceptions (any real image format): Sliders, Developer `logo`, User `profile_image`

Image URL format in responses

- API responses return a full (absolute) URL for file/image fields (including user `profile_image`) when request context is available (typical in DRF views), e.g. `{{baseurl}}/media/...`.

Where files are stored

- Uploaded files are stored in the database (DB-backed storage) and served via `GET /media/<path>`.

Unit Types

- Resource: `/api/unit/types/`

Endpoints

- `GET /api/unit/types/` (list)
- `GET /api/unit/types/{id}/` (retrieve)
- `POST /api/unit/types/` (create)
- `PUT /api/unit/types/{id}/` (update)
- `PATCH /api/unit/types/{id}/` (partial update)
- `DELETE /api/unit/types/{id}/` (delete)

Permissions

- Public: `GET` (list/retrieve)
- Staff/Manager/Superuser: `POST`, `PUT`, `PATCH`
- Manager/Superuser: `DELETE`

Fields

Required on create:

- `name_en` (string)
- `name_ar` (string)

Read-only:

- `id`

List example

- **GET** `/api/unit/types/`

- **200 OK**

```
[
  {"id": 1, "name_en": "Apartment", "name_ar": "شقة"},
  {"id": 2, "name_en": "Villa", "name_ar": "فيلا"}
]
```

Create example (JSON)

- **POST** `/api/unit/types/`

```
{
  "name_en": "Townhouse",
  "name_ar": "تاون هاوس"
}
```

Response example

```
{
  "id": 3,
  "name_en": "Townhouse",
  "name_ar": "تاون هاوس"
}
```

Countries

- Resource: `/api/countries/`

List filtering

- Default: `GET /api/countries/` returns only `appear_on_home_page=true`.
- Options:
  - `GET /api/countries/?appear_on_home_page=true`
  - `GET /api/countries/?appear_on_home_page=false` #for dashboard or all
  - `GET /api/countries/?appear_on_home_page=all` (returns all)

Endpoints

- `GET /api/countries/` (list)
- `GET /api/countries/{id}/` (retrieve)
- `POST /api/countries/` (create)
- `PUT /api/countries/{id}/` (update)
- `PATCH /api/countries/{id}/` (partial update)
- `DELETE /api/countries/{id}/` (delete)

Permissions

- Public: `GET` (list/retrieve)
- Staff/Manager/Superuser: `POST`, `PUT`, `PATCH`
- Manager/Superuser: `DELETE`

Fields

Required on create:

- `name_en` (string)
- `name_ar` (string)
- `image` (file)

Optional:

- `appear_on_home_page` (boolean; defaults to `false`)

Read-only:

- `id`
- `created_at`

Create example (multipart/form-data)

Fields:

- `name_en`: `Egypt`
- `name_ar`: `مصر`
- `appear_on_home_page`: `true`
- `image`: (file)

Response example

```
{
  "id": 1,
  "name_en": "Egypt",
  "name_ar": "مصر",
  "image": "{{baseurl}}/media/countries/egypt.png",
  "appear_on_home_page": true,
  "created_at": "2025-12-25T12:34:56Z"
}
```

Cities

- Resource: `/api/cities/`

List filtering

- Default: `GET /api/cities/` returns only `appear_on_home_page=true`.
- Options:
  - `GET /api/cities/?appear_on_home_page=true`
  - `GET /api/cities/?appear_on_home_page=false`
  - `GET /api/cities/?appear_on_home_page=all` (returns all)

Endpoints

- `GET /api/cities/` (list)
- `GET /api/cities/{id}/` (retrieve)
- `POST /api/cities/` (create)
- `PUT /api/cities/{id}/` (update)
- `PATCH /api/cities/{id}/` (partial update)
- `DELETE /api/cities/{id}/` (delete)

Permissions

- Public: `GET` (list/retrieve)
- Staff/Manager/Superuser: `POST`, `PUT`, `PATCH`
- Manager/Superuser: `DELETE`

Fields

Required on create:

- `country` (number; Country ID)
- `name_en` (string)
- `name_ar` (string)
- `image` (file)

Optional:

- `appear_on_home_page` (boolean; defaults to `false`)

Read-only:

- `id`
- `country_name` (string; derived from country `name_en`)
- `created_at`
- `updated_at`

Create example (multipart/form-data)

Fields:

- `country`: `1`
- `name_en`: `Cairo`
- `name_ar`: `القاهرة`
- `appear_on_home_page`: `true`
- `image`: (file)

Response example

```
{
  "id": 1,
  "country": 1,
  "country_name": "Egypt",
  "name_en": "Cairo",
  "name_ar": "القاهرة",
  "image": "{{baseurl}}/media/cities/cairo.png",
  "appear_on_home_page": true,
  "created_at": "2025-12-25T12:34:56Z",
  "updated_at": "2025-12-25T12:34:56Z"
}
```

Sliders

- Resource: `/api/sliders/`

List filtering

- Default: `GET /api/sliders/` returns only `appear_on_home_page=true`.
- Options:
  - `GET /api/sliders/?appear_on_home_page=true`
  - `GET /api/sliders/?appear_on_home_page=false`
  - `GET /api/sliders/?appear_on_home_page=all` (returns all)

Endpoints

- `GET /api/sliders/` (list)
- `GET /api/sliders/{id}/` (retrieve)
- `POST /api/sliders/` (create)
- `PUT /api/sliders/{id}/` (update)
- `PATCH /api/sliders/{id}/` (partial update)
- `DELETE /api/sliders/{id}/` (delete)

Permissions

- Public: `GET` (list/retrieve)
- Staff/Manager/Superuser: `POST`, `PUT`, `PATCH`
- Manager/Superuser: `DELETE`

Fields

Required on create:

- `image` (file)

Optional:

- `appear_on_home_page` (boolean; defaults to `true`)
- `index` (number; controls ordering; lower comes first)

Read-only:

- `id`
- `created_at`

Response example

```
{
  "id": 1,
  "image": "{{baseurl}}/media/sliders/slide1.jpg",
  "appear_on_home_page": true,
  "index": 0,
  "created_at": "2025-12-25T12:34:56Z"
}
```

Ordering

- Sliders are returned ordered by `index` ascending, then `id`.

Ads

- Resource: `/api/ads/`

Endpoints

- `GET /api/ads/` (list)
- `GET /api/ads/{id}/` (retrieve)
- `POST /api/ads/` (create)
- `PUT /api/ads/{id}/` (update)
- `PATCH /api/ads/{id}/` (partial update)
- `DELETE /api/ads/{id}/` (delete)

Permissions

- Public: `GET` (list/retrieve)
- Staff/Manager/Superuser: `POST`, `PUT`, `PATCH`
- Manager/Superuser: `DELETE`

Fields

Required on create:

- `image` (file)
- `appear_place` (string; one of: `home`, `projects`, `units`, `other`)

Read-only:

- `id`
- `created_at`

Create example (multipart/form-data)

Fields:

- `appear_place`: `home`
- `image`: (file)

Response example

```
{
  "id": 1,
  "image": "{{baseurl}}/media/ads/ad1.jpg",
  "appear_place": "home",
  "created_at": "2025-12-25T12:34:56Z"
}
```

Features

- Resource: `/api/features/`

Endpoints

- `GET /api/features/` (list)
- `GET /api/features/{id}/` (retrieve)
- `POST /api/features/` (create)
- `PUT /api/features/{id}/` (update)
- `PATCH /api/features/{id}/` (partial update)
- `DELETE /api/features/{id}/` (delete)

Permissions

- Public: `GET` (list/retrieve)
- Staff/Manager/Superuser: `POST`, `PUT`, `PATCH`
- Manager/Superuser: `DELETE`

Fields

Required on create:

- `name_en` (string)
- `name_ar` (string)

Read-only:

- `id`

Response example

```
{
  "id": 1,
  "name_en": "Swimming Pool",
  "name_ar": "حمام سباحة"
}
```

Articles

- Resource: `/api/articles/`

Endpoints

- `GET /api/articles/` (list)
- `GET /api/articles/{id}/` (retrieve)
- `POST /api/articles/` (create)
- `PUT /api/articles/{id}/` (update)
- `PATCH /api/articles/{id}/` (partial update)
- `DELETE /api/articles/{id}/` (delete)

Permissions

- Public: `GET` (list/retrieve)
- Content Creator / Manager / Superuser: `POST`, `PUT`, `PATCH`
- Content Creator / Manager / Superuser: `DELETE`

Fields

Required on create:

- `title_en` (string)
- `title_ar` (string)
- `content_en_md` (string; markdown)
- `content_ar_md` (string; markdown)
- `image` (file)

Optional:

- `meta` (object; can be null)

Read-only:

- `id`
- `created_at`
- `updated_at`

Create example (multipart/form-data)

Fields:

- `title_en`: `Market Update`
- `title_ar`: `تحديث السوق`
- `content_en_md`: `# Heading\n\nMarkdown...`
- `content_ar_md`: `# عنوان\n\nMarkdown...`
- `meta`: `{ "tags": ["news"], "reading_time": 5 }`
- `image`: (file)

Response example


```
{
  "id": 1,
  "title_en": "Market Update",
  "title_ar": "تحديث السوق",
  "content_en_md": "# Heading\n\nMarkdown...",
  "content_ar_md": "# عنوان\n\nMarkdown...",
  "meta": {"tags": ["news"], "reading_time": 5},
  "image": "{{baseurl}}/media/articles/article1.jpg",
  "created_at": "2025-12-25T12:34:56Z",
  "updated_at": "2025-12-25T12:34:56Z"
}
```

Permission quick matrix (core)

- **Public (no token)**: list/retrieve for all core resources
- **Staff/Manager/Superuser**: create/update for Countries, Cities, Sliders, Ads, Features
- **Manager/Superuser**: delete for Countries, Cities, Sliders, Ads, Features
- **Unit Types**:
  - public: list/retrieve
  - create/update: Staff OR Manager OR Superuser
  - delete: Manager OR Superuser
- **Articles**:
  - create/update: Content Creator OR Manager OR Superuser
  - delete: Content Creator OR Manager OR Superuser

Customer API endpoints (`/api/customer/`)

Customer Inquiries

- Resource: `/api/customer/inqury/` (note: `inqury` is the backend path)

Endpoints

- `POST /api/customer/inqury/` (create inquiry; customer only)
- `GET /api/customer/inqury/` (list inquiries; staff/manager/superuser)

- `PATCH /api/customer/inqury/{id}/contacted/` (update only `is_contacted`; staff/manager/superuser)

Create inquiry (Website/App)

- **POST** `/api/customer/inqury/`
- **Auth**: Yes
- **Role**: `customer`
- **Content-Type**: `application/json`

Request body fields

Required:

- `phone` (string)
- `message` (string)
- `interested_in` (number; UnitType ID)
- `project_id` (number) and/or `unit_id` (number)

Not allowed / read-only:

- `customer_id` (derived from authenticated user)
- `is_contacted` (defaults to `false`, staff updates it later)
- `created_at`

Example (JSON)

```
{
  "phone": "+201234567890",
  "message": "I want more details",
  "interested_in": 1,
  "project_id": 10
}
```

Success response

- **201 Created**

```
{
  "id": 5,
  "customer_id": 1,
  "phone": "+201234567890",
  "message": "I want more details",
  "interested_in": 1,
  "interested_in_name_en": "Apartment",
  "interested_in_name_ar": "شقة",
  "project_id": 10,
  "unit_id": null,
```

```
  "is_contacted": false,
  "created_at": "2026-01-31T10:15:30Z"
}
```

Common error responses

- **400 Bad Request** (validation)

```
{
  "interested_in": ["This field is required."]
}
```

```
{
  "non_field_errors": ["Provide project_id and/or unit_id."]
}
```

- **403 Forbidden** (not a customer)

List inquiries (Dashboard)

- **GET** `/api/customer/inqury/`
- **Auth**: Yes
- **Role**: `staff|manager|superuser`

Success response

- **200 OK**

```
[
  {
    "id": 5,
    "customer_id": 1,
    "phone": "+201234567890",
    "message": "I want more details",
    "interested_in": 1,
    "interested_in_name_en": "Apartment",
    "interested_in_name_ar": "شقة",
    "project_id": 10,
    "unit_id": null,
    "is_contacted": false,
    "created_at": "2026-01-31T10:15:30Z"
  }
]
```

Mark inquiry as contacted (Dashboard)

- **PATCH** `/api/customer/inqury/{id}/contacted/`
- **Auth**: Yes
- **Role**: `staff|manager|superuser`
- **Content-Type**: `application/json`

Request body

```
{
  "is_contacted": true
}
```

Success response

- **200 OK**

```
{
  "is_contacted": true
}
```

Common error responses

- **404 Not Found** (invalid inquiry id)
- **403 Forbidden** (not staff/manager/superuser)

Django Admin (server panel)

- URL: `/admin/`
- Access: only users with `is_superuser=true` (created via `python manage.py createsuperuser`).